

FINBRIDGE SOLUTIONS

IAM Access Control Review

Prepared by: Pavithra Tippareddy

Date: June 2026

Classification: Confidential

Version: 1.0

Platform: Microsoft Entra ID (Free Tier)

Framework References:

ISO 27001:2022 Annex A.9 | NIST CSF PR.AC | GDPR Article 5(1)(f)

1. EXECUTIVE SUMMARY

This IAM access control review was conducted for FinBridge Solutions, a fictional 45-person fintech company processing customer payments and handling sensitive financial data. The objective was to design and assess role-based access controls across 11 internal systems, identify access control gaps, and produce a remediation framework aligned with ISO 27001 Annex A.9 (Access Control) and GDPR Article 5 (data minimisation).

The review covered 8 role types and resulted in 4 risk findings — 2 rated High severity, 1 Medium, and 1 Informational. Key issues identified include unrestricted IT Administrator privileges across all systems, uncontrolled contractor account lifecycle, and C-Suite simultaneous access to multiple sensitive data systems without dual-control enforcement.

The access matrix was implemented in Microsoft Entra ID (Free Tier) — users, security groups, and directory role assignments were created in the live environment, and a full contractor offboarding simulation was performed with audit log evidence captured.

This document presents the access matrix, risk findings, IT Administrator offboarding procedure, Entra ID implementation evidence, and recommendations for remediation.

2. METHODOLOGY

Access entitlements were assessed and implemented using a role-based access control (RBAC) framework built on the following principles:

- Least Privilege — users receive only the minimum access required for their role
- Need-to-Know — access is granted based on documented business justification, not convenience
- Segregation of Duties (SoD) — conflicting access rights are identified and flagged for remediation
- Accountability — every group and account has a named owner responsible for access decisions

Framework references:

- ISO 27001:2022 Annex A.9 — Access Control: the core standard governing who gets access to what, how it is managed, and how it is revoked
- NIST Cybersecurity Framework — Protect (PR.AC): Identity Management and Access Control
- GDPR Article 5(1)(f) — Integrity and Confidentiality: personal data must be protected against unauthorised access using appropriate technical measures

Implementation approach:

- Access matrix designed in Excel covering 8 roles across 11 systems with colour-coded risk levels
- Matrix implemented in Microsoft Entra ID Free Tier — 8 users created, 6 security groups configured, directory roles assigned
- Contractor offboarding procedure simulated in live Entra ID environment with full audit log evidence captured
- Free-tier limitations identified and documented as additional risk findings with upgrade recommendations

3. ACCESS MATRIX SUMMARY

The full access matrix covering 8 roles across 11 systems is provided in the accompanying file: FinBridge_IAM_Access_Matrix.xlsx. The matrix uses four access levels:

- Full Access — read, write, modify, and delete permissions (colour coded red)
- Read Only — view access with no modification rights (colour coded yellow)

- Scoped Access — limited to specific functions, time-bound for contractors (colour coded blue)
- No Access — blocked from system entirely

Security groups implemented in Microsoft Entra ID:

- FinBridge-Privileged-Admins — IT Administrator (Alex Rivera)
- FinBridge-Developers — Developer + Vendor Contractor
- FinBridge-Finance — Finance Officer + CEO FinBridge
- FinBridge-HR — HR Manager
- FinBridge-CustomerSupport — Support Agent
- FinBridge-ReadOnly-Security — Security Analyst

Directory roles assigned in Microsoft Entra ID:

- Alex Rivera (IT Administrator) — Global Administrator: full tenant access, mirrors Full Access across all systems
- Security Analyst — Global Reader: read-only access across tenant, mirrors Read Only on identity and endpoint systems
- HR Manager — User Administrator: scoped identity management rights for employee onboarding and offboarding

Key observations from the matrix:

- IT Administrator holds Full Access across all 11 systems — highest risk profile, Finding 1
- Security Analyst correctly restricted to Read Only on identity and endpoint systems — appropriate for monitoring role
- Developer correctly has No Access to Payment Gateway — Segregation of Duties compliance confirmed, Finding 2
- Contractor accounts have Scoped Access to 2 systems but no defined expiry — orphaned account risk, Finding 4
- C-Suite has simultaneous Read Only access to Finance and HR systems — data aggregation risk, Finding 3

4. RISK FINDINGS

Finding 1 — Unrestricted Privileged Access: IT Administrator

Field	Detail
Affected Role	IT Administrator
Systems Affected	All 11 systems
Access Level	Full Access
Severity	HIGH
ISO 27001 Ref	Annex A.9.2.3 — Management of privileged access rights

Risk Description:

The IT Administrator account holds unrestricted Full Access across all 11 systems including HR, Finance, Payment Gateway, and identity infrastructure. This creates a single point of compromise — if the admin account is breached through phishing, credential theft, or insider threat, an attacker gains immediate, undetected access to the entire environment with no access boundaries.

Recommendation:

- Implement Privileged Access Management (PAM) — restrict admin access to only what is needed for each specific task
- Enforce Just-In-Time (JIT) access for sensitive systems — admin rights granted on request and expire automatically
- Require MFA for all administrative actions
- Conduct quarterly access reviews on all privileged accounts
- Consider Microsoft Entra ID P2 for Privileged Identity Management (PIM)

INTERVIEW ANSWER GUIDE

"In my IAM review for FinBridge Solutions, the most critical finding was that the IT Administrator had Full Access across all 11 systems with no restrictions. ISO 27001 Annex A.9.2.3 specifically requires that privileged access rights be allocated on a need-to-use basis and reviewed regularly. I flagged this as High severity because a single compromised account would give an attacker unrestricted access to payment systems, HR data, and identity infrastructure simultaneously. My recommendation was to implement Just-In-Time access and Privileged Access Management, and to consider Entra ID P2 for PIM so admin rights are granted only when needed and expire automatically after use. This is the zero-trust principle applied to identity."

Finding 2 — Developer SoD Compliance: Payment Gateway

Field	Detail
Affected Role	Developer
Systems Affected	Payment Gateway
Access Level	No Access — compliant
Severity	INFORMATIONAL
ISO 27001 Ref	Annex A.9 — Access Control (SoD principle)

Risk Description:

No violation found. The Developer role correctly has no access to the Payment Gateway, maintaining segregation of duties between development and financial transaction systems. In a fintech environment, developer access to payment infrastructure would allow manipulation of transaction logic or exfiltration of payment data — the separation is critical and is confirmed compliant.

Recommendation:

- Maintain this control at all times — do not grant temporary or emergency developer access to payment systems without formal written approval and documented business justification
- Verify this control at every access review cycle — do not assume it is in place without checking
- If emergency access is ever required, ensure it is time-limited, fully logged, and revoked immediately after resolution

INTERVIEW ANSWER GUIDE

"One of my findings was actually a positive one — confirming that the Developer role had no access to the Payment Gateway. In a fintech context, this is a critical segregation of duties control. If a developer could access payment infrastructure, they could potentially alter transaction logic or exfiltrate card data. ISO 27001 Annex A.9 requires that access is restricted based on business need, and there is no legitimate reason for a developer to access live payment systems. I documented this as Informational to confirm the control was working correctly and to flag that it must be actively maintained and verified at every access review — not just assumed to be in place."

Finding 3 — C-Suite Dual Data Access: Finance and HR Systems

Field	Detail
Affected Role	C-Suite / Executive
Systems Affected	Finance System + HR System
Access Level	Read Only
Severity	MEDIUM
ISO 27001 Ref	Annex A.9.4.1 — Information access restriction
GDPR Ref	Article 5(1)(f) — Integrity and Confidentiality

Risk Description:

C-Suite accounts have simultaneous Read Only access to both financial data and HR personnel records. While Read Only reduces modification risk, the combination creates a data aggregation risk — an insider threat or compromised executive account could exfiltrate both employee salary data and financial transaction records. GDPR Article 5(1)(f) requires that personal data including HR records be protected against unauthorised access, making this a compliance concern in addition to a security risk.

Recommendation:

- Enforce MFA on both Finance and HR systems for all C-Suite logins
- Enable detailed audit logging on all C-Suite access sessions — log what data was accessed and when
- Review whether simultaneous access to both systems is a genuine business requirement or whether access can be granted on request
- Classify HR and Finance data as sensitive categories in the data classification policy

INTERVIEW ANSWER GUIDE

"My third finding involved C-Suite accounts having Read Only access to both the Finance System and HR System simultaneously. Even though Read Only reduces the risk of data modification, the concern here is data aggregation — combining financial data with employee records creates a rich target for insider threats or account compromise. ISO 27001 Annex A.9.4.1 requires that access to information is restricted according to the access control policy, and GDPR Article 5(1)(f) requires that personal data — which HR records are — is protected against unauthorised access. I rated this Medium severity because Read Only access limits the blast radius, but I recommended enforcing MFA on both systems and enabling audit logging so any suspicious access patterns are visible."

Finding 4 — Uncontrolled Contractor Account Lifecycle

Field	Detail
Affected Role	Contractor / Vendor
Systems Affected	Code Repository + Customer Portal
Access Level	Scoped Access
Severity	HIGH
ISO 27001 Ref	Annex A.9.2.6 — Removal or adjustment of access rights

Risk Description:

Contractor accounts have Scoped Access to two systems but no defined engagement end date or automatic account expiry. When a contractor engagement ends with no manual deprovisioning triggered, the account remains active — creating orphaned accounts. Orphaned accounts are one of the most common access control failures and can be exploited by former contractors, used in credential stuffing attacks, or overlooked in access reviews. ISO 27001 Annex A.9.2.6 explicitly requires that access rights are removed or adjusted immediately when employment or contract ends.

Recommendation:

- Enforce a maximum 30-day account lifetime for all contractor accounts — accounts expire automatically unless explicitly renewed
- Document the engagement end date at provisioning — this becomes the account expiry trigger
- Assign a named internal account owner responsible for contractor deprovisioning
- Conduct monthly reviews of all contractor and vendor accounts
- Implement an automated offboarding workflow triggered by engagement end date

INTERVIEW ANSWER GUIDE

"My fourth finding was about contractor account lifecycle management — contractor accounts had Scoped Access to the Code Repository and Customer Portal, but there was no defined expiry date or automatic deprovisioning process. This is a classic orphaned account risk. ISO 27001 Annex A.9.2.6 explicitly requires that access rights are removed when a

contract or employment ends — it is one of the clearest requirements in the standard. I rated this High severity because orphaned accounts are frequently exploited: a former contractor with lingering access could exfiltrate source code or customer data long after their engagement ended. My recommendation was a 30-day maximum account lifetime with automatic expiry, a named internal owner for each contractor account, and monthly contractor access reviews to catch anything that slips through."

5. IT ADMINISTRATOR OFFBOARDING PROCEDURE

Purpose

This procedure defines the mandatory steps to be followed when an IT Administrator leaves FinBridge Solutions or has their role changed. IT Administrator accounts hold Full Access across all 11 systems — making timely and complete offboarding critical to preventing unauthorised access after departure.

Trigger

This procedure is initiated by HR on or before the employee's last working day and must be completed within 2 hours of the account holder's last shift ending.

Framework Reference: ISO 27001 Annex A.9.2.6 — Removal or adjustment of access rights

Offboarding Checklist

Step	Action	Responsible	Evidence
1	HR notifies IT Security on or before last working day — include confirmed last shift end time	HR Manager	Email notification on record
2	Disable the Entra ID account immediately at end of last shift — do NOT delete the account	IT Security	Screenshot: Account enabled = No Audit log: Disable account
3	Revoke all active sessions via Entra ID — invalidates all StsRefreshTokens and forces immediate sign-out across all devices	IT Security	Audit log: Update StsRefreshToken — Success
4	Remove account from all Entra ID security groups	IT Security	Screenshot: empty Groups page Audit log: Remove member from group
5	Remove all assigned directory roles — Global Administrator and any other Entra ID roles	IT Security	Screenshot: empty Assigned Roles page
6	Rotate all shared credentials the admin had access to — firewall console passwords, payment gateway service accounts, shared admin passwords	IT Security	Change log entries for each rotated credential
7	Review and reassign any open tickets, change requests, or pending approvals owned by the departing admin	IT Security + Manager	Ticket system records

8	Audit last 30 days of sign-in and audit logs — flag any anomalous access patterns before departure	Security Analyst	Audit log export saved and reviewed
9	Retain disabled account for 30 days before permanent deletion — allows recovery if needed	IT Security	Account status: Disabled — deletion scheduled
10	Formal sign-off — HR and IT Security Lead confirm procedure complete and document in offboarding register	HR + IT Security Lead	Signed offboarding record filed

Evidence from Microsoft Entra ID Lab Simulation

The following offboarding steps were performed in a live Microsoft Entra ID Free Tier environment using the Vendor Contractor account as the simulation subject. All actions are confirmed in the Entra ID audit log.

Action Performed	Audit Log Entry	Screenshot File
Account disabled	Disable account — Success	06_vendor_account_disabled.png
Sessions revoked	Update StsRefreshToken — Success	07_vendor_sessions_revoked.png
Removed from group	Remove member from group — Success	08_vendor_groups_removed.png
Full audit trail captured	All lifecycle events visible with timestamps and actor	09_vendor_audit_log.png

Note on audit log terminology:

In Microsoft Entra ID Free Tier, session revocation appears in the audit log as “Update StsRefreshToken” rather than “Revoke sessions”. StsRefreshToken refers to the Security Token Service Refresh Token — invalidating it forces immediate re-authentication across all active sessions. This is the technical action behind session revocation in the Microsoft identity platform.

Why IT Administrator Offboarding is High Priority

Unlike standard user offboarding, IT Administrator departures carry additional risk because:

- Admin accounts have Full Access across all systems — a single missed step leaves the entire environment exposed
- Admins often know shared credentials, service account passwords, and system configurations that must be rotated
- Admin actions are harder to detect post-departure if audit logging is not reviewed promptly
- ISO 27001 Annex A.9.2.6 requires that access rights are removed immediately when employment ends — not at the next scheduled review

6. RECOMMENDATIONS SUMMARY

#	Finding	Severity	Recommended Action	Priority
---	---------	----------	--------------------	----------

1	IT Admin unrestricted access	High	Implement PAM + JIT access; enforce MFA on all admin actions; quarterly privilege review	Immediate
2	Developer SoD compliance	Info	Maintain control; verify at each access review that no emergency access has been granted without approval	Ongoing
3	C-Suite dual data access	Medium	Enforce MFA on Finance and HR systems; enable audit logging on all C-Suite sessions	30 days
4	Contractor account lifecycle	High	Enforce 30-day account expiry; assign account owner; conduct monthly contractor access reviews	Immediate

7. ENTRA ID FREE TIER — IDENTIFIED LIMITATIONS & UPGRADE PATH

This project was implemented using Microsoft Entra ID Free Tier. The following features were unavailable and represent additional security gaps that would be present in any organisation using only the free tier. These are documented as recommendations for future improvement.

Feature	Limitation	Security Risk	Recommendation
Conditional Access	Cannot enforce MFA per-app or per-risk level	No policy-based access control on sensitive systems	Upgrade to Entra ID P1
Access Reviews	Cannot schedule automated quarterly reviews	Privileged access is never automatically reviewed	Upgrade to Entra ID P2
Privileged Identity Management (PIM)	Cannot implement Just-In-Time admin access	Admin rights are always-on instead of time-limited	Upgrade to Entra ID P2
Automated Deprovisioning	No SCIM provisioning to SaaS apps	Contractor offboarding requires manual steps	Entra ID P1 + SCIM integration

APPENDIX — FRAMEWORK REFERENCE GUIDE

Quick reference for the standards cited in this report. Use this section for interview preparation.

ISO 27001:2022 Annex A.9 — Access Control

The access control section of ISO 27001. Sets requirements for managing who can access what systems and data, based on business need. Key principles: least privilege, need-to-know, regular access reviews, and timely revocation when access is no longer required. This is the primary standard referenced throughout this report.

ISO 27001 Annex A.9.2.3 — Management of Privileged Access Rights

Specifically addresses privileged accounts such as admins and superusers. Requires that privileged access rights are allocated on a need-to-use basis, documented, reviewed regularly, and minimised. Direct basis for Finding 1 (IT Administrator unrestricted access).

ISO 27001 Annex A.9.2.6 — Removal or Adjustment of Access Rights

Requires that access rights are removed, adjusted, or transferred immediately when employment, contract, or role changes. Direct basis for Finding 4 (contractor orphaned accounts) and the IT Admin offboarding procedure in Section 5.

ISO 27001 Annex A.9.4.1 — Information Access Restriction

Requires that access to information and systems is restricted in accordance with the access control policy. Supports Finding 3 (C-Suite dual data access) — even Read Only access should be justified and logged when it covers sensitive data categories.

NIST Cybersecurity Framework — Protect (PR.AC)

The NIST CSF Protect function includes identity management and access control as a core category. Covers identity proofing, credentials management, remote access, and access permissions. High-level NIST reference used in this report — easier to cite in interviews than specific NIST SP 800-53 controls and equally valid for private sector contexts.

GDPR Article 5(1)(f) — Integrity and Confidentiality

Requires that personal data is processed with appropriate security, including protection against unauthorised access. Supports Finding 3 — HR records are personal data under GDPR, so C-Suite access to HR systems carries GDPR obligations in addition to access control requirements.